決賽講稿｜AI資安框架

第1至9頁正式報告：口述約260秒＋影片30秒，另留一分鐘緩衝。第10至12頁為答詢備用，共6題。照稿唸即可，數字已寫成口語念法。



01 開場與作品定位 — 15 秒

各位評審好。我們的作品是「融合新型內容相依時序方向模型入侵偵測與任務導向檢索增強稽核之AI資安框架」。簡單講，就是讓每一個告警都說得出依據、拿得出證據，處置完也回得來。我們先看一段三十秒的影片。



02 方法影片（內建配音） — 30 秒

（這頁不用講。影片會自動播放，有配音，大約三十秒；播完停在最後畫面，再手動切到下一頁。）



03 一個框架，四個連續階段 — 40 秒

剛剛影片跑的流程，就是這張圖上的四個階段。第一是流量表徵，從同一筆流量裡取出內容、時間差跟方向。第二是互補判定，兩個模型一起判斷是十七類裡的哪一類、信心多高。第三是證據稽核，拿判定結果去找最像的五筆訓練案例，交給本機的AI核對。第四是受控回復，規則套上去以後會讀回來確認，時間到了自動撤掉。這四段都綁在同一個事件編號上，所以從告警到處置，每一步都查得到。



04 互補模型，形成同一次判定

40 秒

我們先看偵測。兩個模型看同一筆流量，只是角度不一樣。CTBM是我們自己設計的，它看封包內容、時間差跟傳輸方向彼此之間的關係。PBCNN是引用的既有模型，用來補短時間內的位元組模式。兩邊的結果先各自校準，再經過融合閘門，最後只產生一次正式的十七類判定。另外，信心分數跟五百一十二維的流量表徵也會留下來，下一步找證據會用到。



05 把判定變成可核對的證據

45 秒

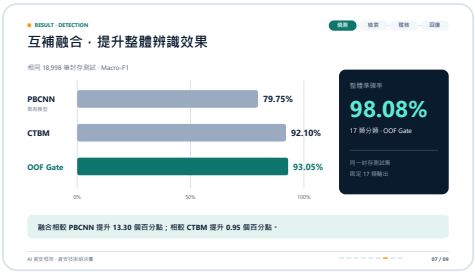
第二步是找證據。我們把剛剛那五百一十二維的流量表徵，再加上十七維的類別機率，組成一個五百二十九維的向量，拿去案例庫找最像的前五筆。案例庫只放訓練資料，跟查詢資料沒有重疊。接著本機AI拿正式判定跟這五筆案例對照，回答支持、複核，或是不確定。AI只做稽核，不能改掉正式分類；而且整個過程都在本機跑，沒有呼叫外部的API。



06 受控處置與到期回復

35 秒

那AI說支持，是不是就直接封鎖？不是。後面還有一道策略閘門，會再檢查信心、證據、允許的動作、影響範圍跟期限，全部通過才套用規則。套上去以後會讀回來，確認真的生效；到期自動撤銷，也確認服務有恢復。如果AI回的是複核或不確定，就只做監測或蒐證。我們用六種隔離TCP情境驗證過，四種套用規則、兩種監測蒐證，六種都完整回復。



07 偵測成果

30 秒

接下來看成果。偵測用的是同一份封存測試資料，一共一萬八千九百九十八筆。看Macro-F1，PBCNN是百分之七十九點七五，CTBM是百分之九十二點一零，兩個融合之後到百分之九十三點零五。整體準確率是百分之九十八點零八。



08 檢索與稽核成果

40 秒

再來是檢索跟稽核。案例庫裡有一千五百五十筆訓練案例，用四百六十三筆查詢去找，前五筆的命中率是百分之九十七點六二。同樣這四百六十三筆交給本機AI稽核：支持四百一十五筆、複核十三筆、不確定三十五筆。AI說支持的裡面，百分之九十七點一一是對的。這兩個數字分開量，一個看檢索、一個看稽核，不能合起來當成防禦率。



09 結語

15 秒

最後總結。我們希望每一個告警不是響一聲就結束，而是留下完整的紀錄：判定、證據、稽核結果，還有處置後有沒有回復。報告到這邊，謝謝各位評審，請指教。



10 答詢｜速度與誤判

報告時不講

Q1：一筆告警從進來到產生處置，要花多久？能即時處理嗎？

我們在RTX 4090暖機之後，做了十七次單筆實測，看中位數：偵測大約三十四毫秒，檢索一點五毫秒，本機AI稽核比較久，大約九百一十四毫秒，加起來差不多零點九五秒，時間主要花在本機AI。不過要先說清楚，這是單筆量測，我們沒有做壓力測試，所以沒辦法說每秒能處理多少筆。

Q2：哪一類攻擊最容易判錯？判錯時系統會怎麼做？

最弱的是Web-XSS，F1只有百分之四十二點七三。測試的一百二十筆裡，有七十一筆被判成Web-BruteForce；Web-BruteForce自己的F1是百分之七十五點一五，是第二低的。這兩類的流量長得很像，所以最容易搞混。判錯的時候還有幾道關卡：AI回複核或不確定、信心不到零點八，或是前五筆裡同類不到四筆，策略都不會放行，會留給人工複核。



11 答詢｜處置與 AI 可靠度

報告時不講

Q3：處置會不會影響正常使用者？規則會一直留著嗎？

我們用策略把影響範圍限住。第一，判成正常類別的流量，不做破壞性處置；第二，動作要在那個類別允許的清單裡；第三，只針對指定的來源跟服務；第四，期限只能設三十到九百秒。我們在六種隔離情境測過，設三十秒的規則，大約三十點一秒就撤銷，背景服務六種都有保留，也都完整回復。不過這是隔離環境的結果，不能直接當成真實攻擊的防禦率。

Q4：本機AI會不會亂判，也就是幻覺？AI判錯了怎麼辦？

AI在我們的系統裡只能回三種答案：支持、複核、不確定，而且要照固定的JSON格式。四百六十三筆全部格式正確，改到正式分類的是零筆；給AI的資料裡也沒有真實標籤。AI說支持的，百分之九十七點一一是對的。錯誤支持有十二筆，其中六筆還是只做蒐證，或被策略擋下來；其他處置一樣要先過信心、證據跟期限的檢查。AI還是會錯，所以我們在它後面多放了一道關卡。



12 答詢 | 新攻擊與導入

報告時不講

Q5：遇到沒看過的新型攻擊怎麼辦？案例庫要怎麼更新？

先講清楚，這次我們沒有量測沒看過的攻擊。目前偵測模型固定輸出十七類。機制上，如果前五筆找不到足夠的同類案例，或是AI回不確定，系統就只蒐證，交給人工確認。人工確認過的案例可以直接加進案例庫，不用改AI的提示。如果要新增一個類別，偵測模型就要重新訓練。

Q6：實際導入一間公司需要什麼？資料會不會外流？

硬體上，一台本機GPU工作站就夠了，上面跑偵測模型、案例庫，還有本機的Llama 3 8B。外部API呼叫是零次，模型權重、輸入資料跟每一筆的回覆都不會傳出去。要接新的流量來源，需要先轉成一樣的欄位跟表徵格式。處置輸出的是路由器規則，目前在Mininet隔離環境驗證過，還沒有接到企業的正式網路。
